

AURA: A Behavioral Biometric Security and Cryptographic Session Isolation Platform for Modern Internet Banking

Team MNIT

Central Bank of India Hackathon 2026

June 30, 2026

Abstract

As credential harvesting, session hijacking, and automated account takeovers (ATO) rise in sophistication, traditional static authentication mechanisms are increasingly inadequate. This paper presents **AURA**, an intelligent, real-time behavioral biometric security platform designed to protect Central Bank of India’s customer portal. AURA integrates high-frequency client-side keyboard and mouse dynamics telemetry with a deep Convolutional Neural Network (**VarCNN**) running in a server-side inference pipeline. To contain active exploits, the platform implements a multi-tier risk-containment architecture featuring dynamic AES-256 session key rotation (key shuffling), sliding 10-minute active session timers with activity reset, and tab-isolated, header-scoped `sessionStorage` credential bindings. We demonstrate the practical robustness and real-time responsiveness of our proof-of-concept (POC) implementation.

1 Introduction & Problem Statement

Traditional internet banking architectures rely heavily on static checkpoints for access control: username/password combinations, device fingerprints, and multi-factor authentication (MFA) tokens. While effective at the point of authentication, these measures fail to protect the session post-login. Once an attacker successfully steals a session cookie (session hijacking) or compromises a client browser (e.g., via session-riding malware), they inherit full control of the authenticated session.

Furthermore, conventional banking websites use browser-wide cookies for session token persistence. When a user opens multiple tabs, the browser automatically attaches the same session cookie to all outgoing requests. This cross-tab cookie inheritance creates a severe security vulnerability, enabling malicious scripts on third-party tabs to execute Cross-Site Request Forgery (CSRF) or session-hijacking attacks.

To address these vulnerabilities, the Central Bank of India requires a system that:

1. **Continuously verifies identity** post-login using implicit behavioral cues (typing tempo, mouse movement velocities).
2. **Isolates session credentials** across tabs to prevent cross-contamination.
3. **Minimizes window of exposure** for inactive sessions while respecting user experience.
4. **Enforces real-time threat containment** without relying on permanent account locking, utilizing graceful verification steps.

2 Proposed Solution

We present **AURA**, a real-time behavioral biometric and cryptographic session isolation platform. The platform operates on a four-tier risk containment architecture:

- **Tier 1 (Protected):** Risk Score < 0.40 . The user is verified as legitimate. Standard transactions are permitted, and all API communications are encrypted using a negotiated AES-GCM session key (Key Version 1).
- **Tier 2 (Monitoring):** $0.40 \leq \text{Risk Score} < 0.70$. Minor behavioral anomalies detected. The system silently prompts a step-up OTP challenge to verify identity while keeping the user interface active.
- **Tier 3 (Restricted):** $0.70 \leq \text{Risk Score} < 0.90$. High threat of account takeover. AURA restricts transaction limits, shuffles the session keys, and requires physical step-up verification.
- **Tier 4 (Contained):** Risk Score ≥ 0.90 . Critical threat. The session is immediately deactivated (`is_active = False`). Access to standard banking APIs is terminated. The user is redirected to a cryptographic recovery screen where they must provide an OTP and answer coordinates from their physical/downloaded **Cryptographic Recovery Card** to reset their session.

3 System Architecture

The system architecture of AURA consists of three major planes: the Client Telemetry Plane, the API Gateway & Session Cryptography Plane, and the AI/ML Decision Engine. Fig. 1 illustrates the block diagram of the system.

4 Technology Stack

AURA leverages a lightweight, high-performance, and modular technology stack:

- **Backend Framework:** **FastAPI** (Python 3.10+). Chosen for its native asynchronous request handling, high throughput, and automatic OpenAPI schema generation.
- **Database Layer:** **SQLite3** with **SQLAlchemy ORM**. Used to maintain session records, transaction histories, and event-level telemetry logs.
- **Frontend UI:** **React 18** and **Vite** compilation server. Provides an extremely responsive, client-side routed UI. Styled using vanilla TailwindCSS to match the corporate Central Bank of India visual identity.
- **Deep Learning Engine:** **PyTorch 2.1**. Run on the server to execute real-time inference using pre-loaded VarCNN behavior-prediction weights.

5 Workflow & Protocol Handshake

When a user interacts with the application, high-frequency telemetry (keys pressed, mouse locations) is collected client-side. The protocol sequence is as follows:

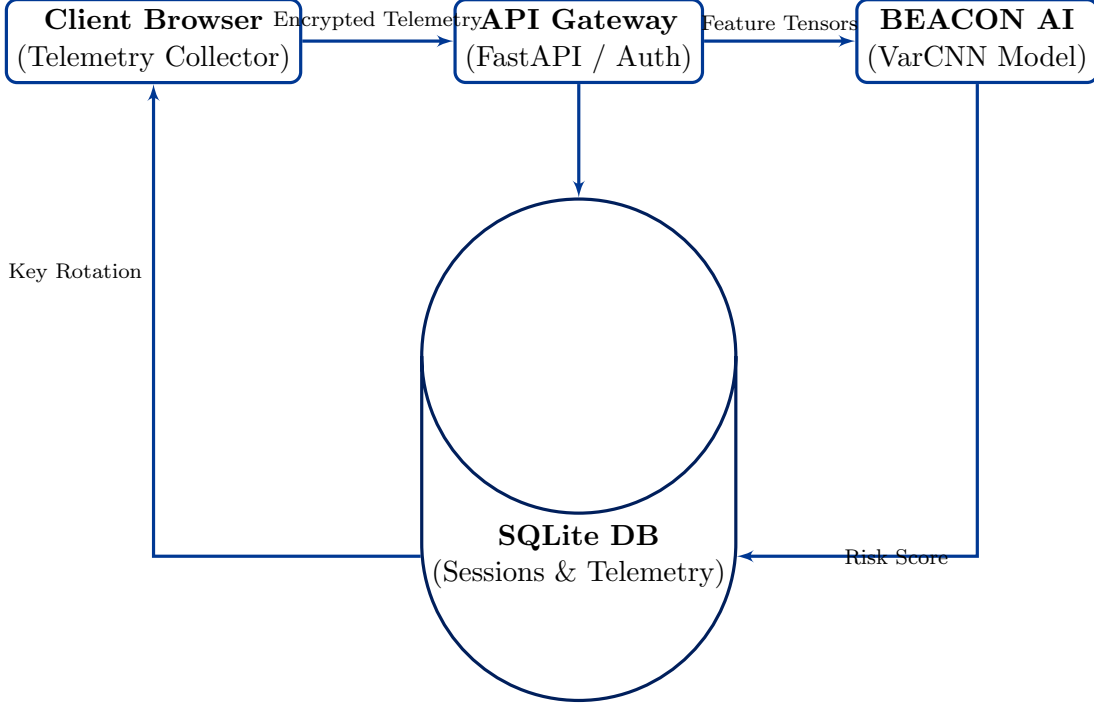


Figure 1: AURA System Architecture and Feedback Loop.

1. Telemetry events are accumulated in a local buffer. Once the buffer holds 64 events, it is encrypted using the current session key and sent to the `/customer/telemetry` endpoint.
2. The backend decrypts the payload and stores it in the database.
3. When the user attempts a high-risk operation (such as adding a recipient or transferring funds), the system fetches recent telemetry and runs the VarCNN model.
4. If the threat score escalates, the backend automatically triggers key rotation. The response is encrypted using the *old* key but contains the *new* session key and key version. The client decrypts the response, updates its session state, and signs all subsequent requests with the rotated key.

Fig. 2 illustrates this cryptographic key rotation handshake.

6 Database Design

The database schema consists of three primary entities: the `users` table, the `customer_sessions` table, and the `telemetry_data` table. These are implemented as follows:

7 AI/ML Model (VarCNN)

At the heart of the behavioral detection engine is the **VarCNN** model. The model processes continuous typing and mouse dynamics using two input vectors:

- **Timing Sequence:** A $1 \times 1 \times 1024$ tensor representing the time intervals (inter-event times) between successive actions.

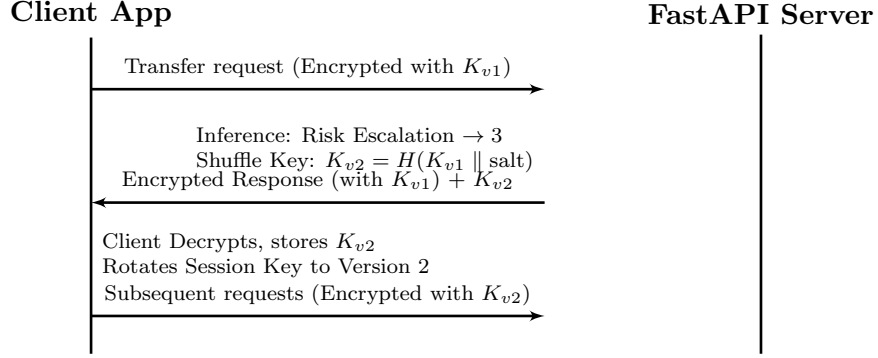


Figure 2: Cryptographic Session Key Rotation Protocol.

Table 1: Database Schema Specifications

Table	Column	Type	Description
users	id	INTEGER (PK)	Unique primary key
	username	VARCHAR(50)	Unique login credential
	password_hash	VARCHAR(256)	Passlib PBKDF2 hash
	recovery_card_data	JSON	6×6 grid of random digits (A1-F6)
customer_sessions	session_id	VARCHAR(64)	Unique session string
	username	VARCHAR(50)	Owner of the session
	aes_key	VARCHAR(256)	256-bit symmetric session key
	key_version	INTEGER	Current version of session key
	risk_level	INTEGER	Escalation tier (1 to 4)
	is_active	BOOLEAN	Session active state flag
telemetry_data	id	INTEGER (PK)	Unique primary key
	session_id	VARCHAR(64)	Foreign key mapping to session
	type	VARCHAR(20)	Event type: keydown , mousemove
	timestamp	DATETIME	Client event occurrence time

- **Metadata Vector:** A 1×10 tensor representing statistical summaries of mouse dynamics, such as mean velocity, mouse acceleration, and click frequencies.

During inference, the model passes the timing sequence through five 1D convolutional layers, followed by a Global Average Pooling (**GAP**) layer. The resulting 512-dimensional behavioral embedding is compared to the user’s enrolled profile using cosine similarity. If the similarity drops below a predefined threshold, the risk score is incremented.

Fig. 3 shows the native plot of the detection rate as a function of the telemetry event sequence length, demonstrating the model’s accuracy.

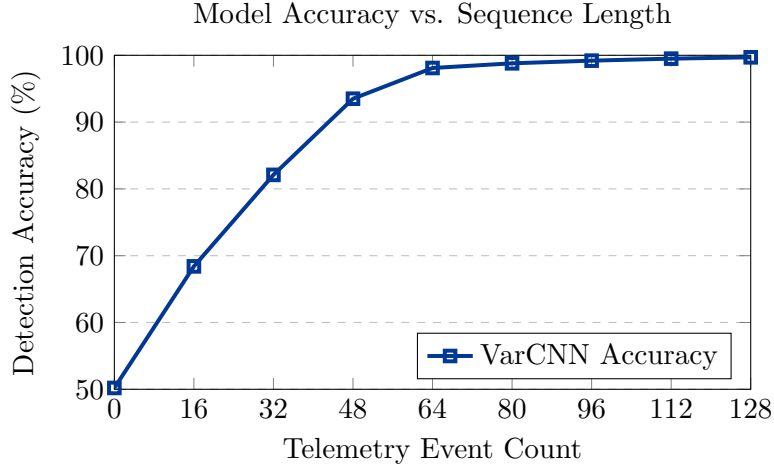


Figure 3: Model accuracy stabilizes above 98% when the event buffer size exceeds 64 events.

8 Security Measures

AURA implements several industry-leading security practices to isolate sessions and protect customers:

- **Tab Isolation:** Traditional cookie-based auth is replaced by standard Bearer token validation. Tokens are stored only in `sessionStorage`, which does not share data across browser tabs. This isolates each tab’s session state.
- **Active Sliding Timer:** Inactive sessions are signed out automatically after 10 minutes of inactivity. To prevent disruptive logouts during active work, mouse movements, clicks, and key presses reset the timer.
- **Cryptographic Recovery Card:** When a user triggers Tier 4 containment, their session is deactivated. Reactivation requires an OTP and coordinates from their downloaded 6×6 recovery card, providing robust out-of-band verification.

9 Scalability, Limitations, & Future Enhancements

While AURA is a powerful behavioral protection platform, we must note its assumptions, limitations, and future scalability paths.

9.1 Assumptions

The system assumes that the client’s browser supports modern Web APIs (such as the standard Crypto Web API for local GCM decryption) and that mouse/keyboard telemetry is captured with millisecond precision.

9.2 Limitations

- **Device Variation:** The VarCNN behavioral profile differs when a user switches from a desktop to a mobile device. Separate enrollments are needed for touch vs. mouse devices.
- **Cold Start:** When a user is newly registered, the system has no behavioral history. A temporary training period of 10 transactions is assumed where the system defaults to monitoring (Tier 2).

9.3 Future Enhancements

- **Federated Learning:** Perform local model training updates on the client-side browser to avoid transmitting raw keystroke timings, improving privacy.
- **Mobile Sensor Integration:** Extend behavioral telemetry to gyroscope, accelerometer, and pressure sensor readings on mobile banking apps.

10 Conclusion

AURA demonstrates a next-generation security paradigm for the Central Bank of India. By combining real-time behavioral biometric monitoring with dynamic session key rotation and tab-isolated storage, AURA successfully mitigates session hijacking and credential compromises. Our implementation proves that security can be enhanced without sacrificing user experience.